

TP : Rempart Linux (Physique, Intégrité et MFA)

Objectifs

1. Verrouiller le chargeur d'amorçage (GRUB) par un hachage cryptographique (PBKDF2).
2. Interdire physiquement l'utilisation de supports de stockage amovibles (USB Storage Blacklist).
3. Configurer et initialiser un système de surveillance d'intégrité des fichiers (AIDE).
4. Déployer l'Authentification Multi-Facteurs (MFA / TOTP) sur le service d'accès distant (SSH).

Sécurisation du chargeur d'amorçage (GRUB)

Par défaut, tout utilisateur ayant accès au clavier peut éditer les paramètres de démarrage du noyau et obtenir un shell root sans mot de passe.

1.1 Génération du hachage PBKDF2

1. Générez un mot de passe sécurisé haché pour GRUB (choisissez une phrase secrète robuste, par exemple AdminGrub2026!) :
`grub-mkpasswd-pbkdf2`
2. **Copiez précieusement la chaîne de caractères** générée (qui commence par `grub.pbkdf2.sha512...`).

1.2 Déclaration du super-utilisateur

1. Ouvrez le fichier de configuration personnalisé de GRUB :
`sudo nano /etc/grub.d/40_custom`
2. Ajoutez à la fin du fichier les lignes suivantes (en remplaçant le hash par celui que vous venez de copier) :
`set superusers="admin"`
`password_pbkdf2 admin grub.pbkdf2.sha512.10000. VOTRE_HASH_ICI...`
3. Sauvegardez et quittez.
4. Mettez à jour la configuration active du système :
`sudo update-grub`

Résultat : Désormais, si quelqu'un tente d'appuyer sur la touche `e` au démarrage pour modifier

les paramètres du noyau, GRUB exigera la saisie du compte admin et de son mot de passe.

Neutralisation des ports USB (Blacklisting)

Pour empêcher un attaquant d'introduire des périphériques malveillants (Rubber Ducky, clés d'exfiltration), nous désactivons le chargement du module noyau gérant les clés USB.

1. Créez un fichier de configuration pour bloquer le module usb-storage :
`sudo nano /etc/modprobe.d/blacklist-usb.conf`
2. Insérez la directive de neutralisation :
`install usb-storage /bin/true`
3. Sauvegardez et quittez. (Au prochain redémarrage, le montage de clés USB sera physiquement impossible au niveau du noyau).

Contrôle d'Intégrité des Fichiers (FIM avec AIDE)

Nous allons installer AIDE pour prendre une "photographie" cryptographique de nos binaires système et détecter la moindre modification (Rootkit).

3.1 Installation et initialisation

1. Installez le paquet AIDE :
`sudo apt-get install aide -y`
2. Initialisez la base de données de référence (cette opération prend quelques secondes) :
`sudo aideinit`
3. La base générée se nomme aide.db.new. Renommez-la en base active de référence :
`sudo cp /var/lib/aide/aide.db.new /var/lib/aide/aide.db`

3.2 Simulation d'une altération et détection

1. Modifions volontairement un fichier système critique pour simuler un attaquant modifiant un binaire :
`sudo touch /bin/fichier_corrompu_malveillant`
2. Lancez un audit d'intégrité manuellement :
`sudo aide --check`

Résultat attendu : AIDE va analyser le système, comparer l'état actuel avec la base de référence, et signaler l'ajout (ou la modification) non autorisée du fichier dans /bin.

Mise en œuvre du MFA sur SSH (TOTP)

Nous allons durcir l'accès SSH de la machine en exigeant un code à 6 chiffres généré par une application smartphone (Google Authenticator, Microsoft Authenticator, FreeOTP).

4.1 Installation du module PAM

1. Installez le module Google Authenticator pour Linux :
`sudo apt-get install libpam-google-authenticator -y`
2. Lancez la configuration pour votre utilisateur (formation) :
`google-authenticator`
3. Répondez aux questions interactives :
 - Souhaitez-vous des tokens basés sur le temps (Time-based) ? **Y (Oui)**
 - Voulez-vous mettre à jour votre fichier `.google_authenticator` ? **Y (Oui)**
 - Voulez-vous interdire l'utilisation multiple du même token (Anti-Replay) ? **Y (Oui)**
 - Voulez-vous ajuster la fenêtre de tolérance temporelle ? **N (Non)**
 - Voulez-vous activer la limitation du taux de requêtes (Rate-limiting) ? **Y (Oui)**

(Un grand QR Code va s'afficher dans votre terminal. Vous pouvez le scanner avec l'application Authenticator de votre smartphone, ou noter la clé secrète fournie).

4.2 Configuration de la pile PAM et d'OpenSSH

1. Éditez la configuration PAM du service SSH pour exiger le module :
`sudo nano /etc/pam.d/sshd`

Ajoutez la ligne suivante tout en haut du fichier :
`auth required pam_google_authenticator.so`
2. Modifiez le fichier de configuration OpenSSH pour autoriser l'interaction clavier :
`sudo nano /etc/ssh/sshd_config`

Assurez-vous que les directives suivantes sont configurées ainsi :
`KbdInteractiveAuthentication yes`
`AuthenticationMethods publickey,keyboard-interactive password,keyboard-interactive`
3. Testez la syntaxe et redémarrez le service SSH :
`sudo sshd -t`
`sudo systemctl restart ssh`

Résultat : Lors de votre prochaine connexion, le serveur vous demandera votre mot de passe habituel, suivi immédiatement de la demande d'un Verification code: à 6 chiffres généré par

votre application mobile !